

CertGraph: Heterogeneous Graph Attention Networks for Active Directory Certificate Services Vulnerability Detection and Autonomous Defense

Course Code: ECE 402

Course Title: Project and Thesis

Submitted By—

Student ID: 2002126 Level: 4, Semester: I

Student ID: 2002138 Level: 4, Semester: I

Student ID: 2102151 Level: 4, Semester: I



Submitted To—

Department of Electronics and Communication Engineering

in partial fulfillment of the requirements for the degree of

Bachelor of Science in Electronics and Communication Engineering

Hajee Mohammad Danesh Science and Technology University (HSTU)

Dinajpur-5200, Bangladesh

February, 2025

Certificate

This is to certify that the thesis work entitled “**CertGraph: Heterogeneous Graph Attention Networks for Active Directory Certificate Services Vulnerability Detection and Autonomous Defense**” is carried by the following ID numbers: **2002126, 2002138, 2102151**. To the fullest extent of our knowledge, we assert that this undertaking is an authentic and original contribution to the field. We certify that this thesis has not been previously submitted for the award of any other degree or diploma at this or any other institution.

Signed by the Final Examining committee:

.....
Chairman
Examination Committee

.....
Supervisor
Department of ECE, HSTU

.....
External Member
Examination Committee

.....
Co-Supervisor
Department of ECE, HSTU

.....
Internal Member
Examination Committee

Candidate's Declaration

We hereby declare that the research work presented in this thesis entitled “**CertGraph: Heterogeneous Graph Attention Networks for Active Directory Certificate Services Vulnerability Detection and Autonomous Defense**” is the outcome of an original investigation conducted by us under the supervision of the Department of Electronics and Communication Engineering, Hajee Mohammad Danesh Science and Technology University (HSTU), Dinajpur-5200, Bangladesh.

We further solemnly declare that:

1. This work, or any part thereof, has not been submitted previously to any university or institution for the award of any degree, diploma, or other academic qualification.
2. All material, concepts, and algorithms taken from the published or unpublished work of others have been fully and properly acknowledged and cited in accordance with standard academic referencing protocols.
3. All synthetic datasets, forensic auditing scripts, empirical benchmark routines, and graph learning models described herein were constructed with rigorous adherence to ethical scientific standards and academic integrity.

Date: February, 2025

Place: HSTU, Dinajpur

.....

Student ID: 2002126

Student ID: 2002138

Student ID: 2102151

Department of ECE, HSTU

Dedication

*This thesis is dedicated to our beloved parents,
whose endless sacrifices, prayers, and unconditional love
have been the guiding light of our lives.*

*And to all our respected teachers and mentors,
who inspired our passion for engineering and scientific discovery.*

Acknowledgements

First and foremost, all praises are due to Almighty Allah, the Most Merciful and Most Beneficent, who bestowed upon us the health, strength, patience, and intellect required to complete this project and thesis research successfully.

We express our profound gratitude, respect, and deepest indebtedness to our respected thesis supervisor and co-supervisor in the Department of Electronics and Communication Engineering, Hajee Mohammad Danesh Science and Technology University (HSTU), Dinajpur. Their exemplary guidance, insightful suggestions, constant encouragement, and critical academic reviews were invaluable throughout the formulation, mathematical derivation, experimental validation, and manuscript preparation of this research.

We are deeply thankful to the Chairman and all distinguished faculty members of the Department of Electronics and Communication Engineering, HSTU, for providing a vibrant academic environment, high-quality computational facilities, and continuous moral support during our undergraduate curriculum.

Our sincere gratitude goes to the global open-source cybersecurity and machine learning research communities. In particular, we acknowledge the pioneering work of Will Schroeder and Lee Christensen (SpecterOps) for uncovering the ADCS attack surface; the creators of BloodHound, SharpHound, and Certipy for their foundational offensive graph tools; the developers of the Game of Active Directory (GOAD) laboratory; and the core contributors of PyTorch Geometric and NetworkX.

Finally, we owe an immeasurable debt of gratitude to our parents and families for their unending sacrifices, patience, and blessings throughout our university education. We also express warm appreciation to our batchmates, lab peers, and friends whose intellectual discussions, camaraderie, and encouragement enriched every stage of this thesis journey.

HSTU, Dinajpur
February, 2025

Student ID: 2002126
Student ID: 2002138
Student ID: 2102151
Department of ECE, HSTU

Abstract

Active Directory Certificate Services (ADCS) is deployed across more than 90% of enterprise networks to administer Public Key Infrastructure (PKI) credentials for authentication and encryption. However, subtle architectural misconfigurations across certificate templates, Access Control Lists (ACLs), and issuance policies introduce catastrophic privilege escalation vectors (designated ESC1 through ESC15), enabling unprivileged actors to compromise entire Active Directory domains. Existing auditing utilities (Certipy, BloodHound, PSPKIAudit) are predominantly rule-based and signature-driven: they evaluate isolated template configuration flags via static heuristics without learning from global environment topology, reachability, or multi-hop delegation chains.

This thesis introduces **CertGraph**, the first heterogeneous Graph Neural Network architecture designed for structural vulnerability detection across Active Directory Certificate Services attack graphs. We formalize enterprise identity infrastructure as a typed, directed, heterogeneous multigraph $G = (V, E, \mathcal{T}_V, \mathcal{T}_E)$ and deploy a Heterogeneous Graph Attention Network (Hetero-GAT) equipped with relation-specific message passing and multi-head attention mechanisms to perform inductive node-level classification over certificate templates.

Crucially, our investigation was grounded in an end-to-end **Forensic Audit** of experimental methodology. We uncovered and eliminated critical structural illusions: synthetic positional index leakage (where administrative entities occupy predictable array offsets), baseline information asymmetry (where flat ML baselines are deprived of graph topological features), and test-set memorization under synthetic hard negatives. We mathematically prove that in directed heterogeneous identity graphs containing source-only entities (Users and Computers with zero in-degree), residual skip-connections are indispensable; without them, message-passing aggregation triggers catastrophic representation collapse ($h_v^{(l+1)} = \mathbf{0}$), causing Macro-F1 to collapse from 0.9986 to 0.4768 ($p = 1.31 \times 10^{-6}$).

On a sanitized, leakage-free benchmark of 700 enterprise environments evaluated under 5-fold cross-validation, CertGraph achieves a Macro-F1 score of **0.9986 ± 0.0029** , substantially outperforming signature heuristics ($0.7791 \pm 0.0247, p < 10^{-4}$) and flat ML ($0.8600 \pm 0.0130, p < 10^{-4}$). To probe model reliability, we formulated a novel **Zero-Shot Adversarial Hard Negative** benchmark where models trained on benign environments are tested against non-exploitable templates bearing vulnerable flags. Under this shift, neural models—including GNNs—succumb to shortcut learning, collapsing to 1.59% accuracy by relying on template flags rather than verifying path reachability. Conversely, symbolic graph traversal (BloodHound BFS) retains 84.13% accuracy.

These findings provide the first empirical justification for a **Neuro-Symbolic Hybrid Architecture** in enterprise identity defense: leveraging fast relational GNNs for heuristic risk prioritization ($O(1)$ amortized screening) coupled with symbolic graph algorithms for deterministic exploitability proofs. Finally, we formulate the autonomous edge-severing defense problem as a Stackelberg security game and mathematically prove its NP-hardness via reduction to the Directed Multi-way Cut problem.

Keywords: Active Directory Certificate Services (ADCS), Graph Attention Networks, Heterogeneous Graphs, Identity and Access Management, Neuro-Symbolic Security, Shortcut Learning, Autonomous Cyber Defense.

Table of Contents

List of Acronyms	xi
1 Introduction	1
1.1 The Modern Identity Attack Surface	1
1.2 The Rise of Active Directory Certificate Services (ADCS)	1
1.3 Limitations of Prior Art	2
1.4 Research Questions and Thesis Objectives	2
1.5 Thesis Organization and Roadmap	2
2 Literature Review and Related Work	4
2.1 Identity-Based Attack Surfaces and Lateral Movement	4
2.2 Evolution of Active Directory Certificate Services (ADCS) Research	4
2.3 Graph Neural Networks in Cybersecurity	4
2.4 Shortcut Learning in Machine Learning	5
2.5 Summary of the Research Gap	5
3 Theoretical Foundations and Threat Modeling	6
3.1 Active Directory Architecture and Identity Primitives	6
3.2 Active Directory Certificate Services (ADCS) Mechanics	6
3.3 Taxonomy of ADCS Vulnerability Classes	7
3.4 Formal Threat Model	7
4 Formal Methodology and CertGraph Architecture	8
4.1 Graph Formalization	8
4.2 Entity Feature Space Engineering	8
4.3 CertGraph Hetero-GAT Pipeline	8
4.4 Representation Collapse in Directed Heterogeneous Convolutions (Theorem 1)	9
5 Forensic Audit: Unmasking Experimental Illusions	10
5.1 The Danger of Unchecked Perfection in Security ML	10
5.2 The Four Experimental Illusions	10
5.3 Generator Sanitization and Verification	10
6 Empirical Benchmarking and Evaluation	11
6.1 In-Distribution 5-Fold Cross-Validation	11
6.2 Architectural Ablations: Confirmation of Theorem 1	11
6.3 Zero-Shot Adversarial Hard Negative Benchmark	12
7 Real-World Active Directory Case Studies: GOAD	13
7.1 The Game of Active Directory (GOAD) Multi-Forest Testbed	13
7.2 SharpHound Ingestion Pipeline	13
7.3 Evaluation on Injected Vulnerabilities	13
8 Domain Generalization, Robustness, and Scalability	14
8.1 Domain Transfer Learning on ADSynth Tiered Networks	14
8.2 Sensitivity and Perturbation Robustness	14
8.3 Computational Scalability Benchmarking	14
9 The Neuro-Symbolic Paradigm and Game-Theoretic Defense	15
9.1 Deconstructing Shortcut Learning in Security GNNs	15
9.2 The Two-Tier Neuro-Symbolic Architecture	15
9.3 Stackelberg Security Game Formulation	15

9.4 Complexity Proof (Theorem 2)	15
10 Conclusion, Limitations, and Future Horizons	16
10.1 Summary of Findings	16
10.2 Honest Limitations	16
10.3 Concluding Remarks	16
Appendix: Formal Mathematical Proofs	17
Proof of Theorem 1: Representation Collapse of Source-Only Entities	17
Proof of Theorem 2: NP-Hardness of Minimal-Capacity Edge-Severing	17
Bibliography	18

List of Figures

Figure 1: Heterogeneous Active Directory Certificate Services (ADCS) Graph Schema, showing relationships between security principals, templates, and CAs.	6
Figure 2: Two-hop ESC13 privilege escalation attack path from an unprivileged user through enrollment permissions and issuance policy OID linkage to high-value domain administrative group tokens.	7
Figure 3: CertGraph Hetero-GAT architectural pipeline, detailing relational multi-head attention, residual skip connections, and the 7-class classification head.	9
Figure 4: Correlation and separability heatmap of template configuration flags and augmented topological features across ESC vulnerability classes.	10
Figure 5: CertGraph Confusion Matrix	11
Figure 6: GNN Family Comparison	11
Figure 7: Ablation study showing catastrophic performance collapse when residual skip connections are disabled.	12
Figure 8: Zero-shot adversarial evaluation demonstrating the collapse of neural models (shortcut learning) compared to symbolic BFS path traversal.	12
Figure 9: ADSynth Tiered Transfer	14
Figure 10: Perturbation Robustness	14
Figure 11: Scalability benchmarks showing linear latency scaling and flat bounded RSS memory footprint.	14
Figure 12: The Two-Tier Neuro-Symbolic Architecture pairing fast CertGraph GNN screening with deterministic BloodHound BFS path verification.	15

List of Tables

Table 1: 5-Fold Cross-Validation Performance across 7 Evaluated Models on 700 Enterprise Domains.	11
--	----

List of Acronyms

ACL	Access Control List
AD	Active Directory
ADCS	Active Directory Certificate Services
AWDP	Automated Windows Domain Penetration
BFS	Breadth-First Search
CA	Certificate Authority
CSR	Certificate Signing Request
CV	Cross-Validation
DACL	Discretionary Access Control List
DC	Domain Controller
DDQN	Dueling Double Deep Q-Network
ECE	Electronics and Communication Engineering
EKU	Extended Key Usage
ESC	Escalation Vector (ADCS Misconfiguration Primitive)
GAT	Graph Attention Network
GCN	Graph Convolutional Network
GNN	Graph Neural Network
GOAD	Game of Active Directory
Hetero-GAT	Heterogeneous Graph Attention Network
HSTU	Hajee Mohammad Danesh Science and Technology University
IAM	Identity and Access Management
KDC	Key Distribution Center
LDAP	Lightweight Directory Access Protocol
ML	Machine Learning
MLP	Multi-Layer Perceptron
NP	Nondeterministic Polynomial Time
ODE	Ordinary Differential Equation
OID	Object Identifier
PAC	Privilege Attribute Certificate
PKI	Public Key Infrastructure
RF	Random Forest
SAN	Subject Alternative Name
SID	Security Identifier
SOC	Security Operations Center
TGS	Ticket Granting Service
TGT	Ticket Granting Ticket
XAI	Explainable Artificial Intelligence

1 Introduction

1.1 The Modern Identity Attack Surface

Enterprise security architectures have undergone a fundamental paradigm shift over the past decade. The traditional perimeter defense model—predicated on securing network boundaries via firewalls, intrusion detection systems, and demilitarized zones (DMZs)—has proven wholly inadequate against modern Advanced Persistent Threats (APTs) and sophisticated ransomware operators. Today, the true operational perimeter of an enterprise is its **identity and access management (IAM) fabric**. Within this fabric, Microsoft Active Directory (AD) stands as the undisputed centerpiece, deployed across more than 90% of Fortune 1000 organizations and global enterprise IT infrastructures to manage authentication, authorization, and directory services.

Active Directory is not merely a database of usernames and passwords; it is an immensely dense, dynamic, and heterogeneous relational graph. Entities such as user accounts, computer workstations, domain controllers, security groups, and organizational units are interlinked by intricate webs of Kerberos delegations, group memberships, and Discretionary Access Control Lists (DACLS). When an attacker obtains an initial foothold inside an enterprise network, they execute identity-based lateral movement, traversing implicit trust relationships and privilege delegation edges to escalate their privileges until achieving total domain compromise (**Domain Admin** status).

Modern attackers rarely exploit unpatched operating system vulnerabilities on core domain controllers. Instead, they exploit **architectural misconfigurations**—permissions, delegations, and access rights that are individually legitimate but combinatorially disastrous. By chaining a series of low-privilege rights (such as group memberships, password resets, and certificate enrollments), an attacker can bridge across security tiers and seize administrative control without generating overt anomalies on traditional endpoint security tools.

1.2 The Rise of Active Directory Certificate Services (ADCS)

In 2021, SpecterOps researchers Will Schroeder and Lee Christensen published their seminal whitepaper, *Certified Pre-Owned: Abusing Active Directory Certificate Services* [1]. This work exposed a vast, historically overlooked attack surface: Active Directory Certificate Services (ADCS). ADCS is Microsoft’s native Public Key Infrastructure (PKI) implementation, integrated deeply into Active Directory to issue digital certificates for code signing, smart card logons, TLS encryption, and, crucially, **client authentication**.

Because ADCS relies on complex, legacy directory schema configurations, subtle misconfigurations in certificate templates and CA permissions can allow low-privileged attackers to impersonate arbitrary domain entities—including high-value Domain Admins. SpecterOps formalized these misconfiguration primitives as *Escalation Vectors* (designated ESC1 through ESC8 in the original publication, and expanding to ESC15 by 2024 with discoveries like ESC13, ESC14, and ESC15/CVE-2024-49019 “EKUwu” [2]).

Unlike traditional credential theft techniques (e.g., Mimikatz LSASS dumping), ADCS exploits generate **cryptographically legitimate certificates signed by the enterprise’s trusted Root Certificate Authority**. Once issued, the attacker presents this certificate to the Kerberos Key Distribution Center (KDC) to request a Kerberos Ticket Granting Ticket (TGT) carrying a privileged Privilege Attribute Certificate (PAC). Security Information and Event Management (SIEM) solutions and end-

point sensors perceive the transaction as an entirely benign, legitimate certificate enrollment, rendering ADCS abuse one of the stealthiest and most destructive attack vectors in enterprise cybersecurity.

1.3 Limitations of Prior Art

In response to the ADCS threat, the cybersecurity community developed several automated auditing utilities, most notably **Certipy** [3], **BloodHound** [4], and **PSPKIAudit**. While indispensable for penetration testers and red teams, these tools suffer from three fundamental architectural limitations:

1. **Isolated Attribute Inspection:** Existing scanners evaluate certificate templates in isolation by checking local property flags. In realistic environments, exploitability depends on whether an unprivileged actor possesses an end-to-end authorization path to enroll in the template, modify its DACL, or link an issuance policy. Inspecting template attributes without evaluating the surrounding graph topology results in massive volumes of false positives.
2. **Absence of Contextual Risk Scoring:** Signature-based tools generate unranked lists of vulnerable templates without quantifying the blast radius or the probability of path traversal. Defenders facing hundreds of reported issues have no automated means of prioritizing remediation based on environmental context.
3. **Inability to Generalize to Chained Multi-Hop Misconfigurations:** Modern attack paths frequently chain together subtle cross-object permissions. Handcrafted rules cannot anticipate the combinatorial explosion of potential multi-hop delegation chains.

1.4 Research Questions and Thesis Objectives

This thesis addresses this critical gap by exploring four central research questions:

- **RQ1 (Relational Necessity):** Can a heterogeneous Graph Attention Network effectively learn to classify subtle ADCS vulnerability classes (ESC1–ESC13) by jointly modeling template configurations and directory authorization topology?
- **RQ2 (Architectural Dynamics):** How do the directed, asymmetric topological properties of Active Directory authorization graphs impact standard message passing, and what architectural inductive biases (e.g., residual skip connections) are mathematically necessary to prevent representation collapse?
- **RQ3 (Adversarial Robustness and Shortcut Learning):** When subjected to rigorous out-of-distribution adversarial hard negatives (templates bearing vulnerable flags but lacking valid authorization paths), do neural security models genuinely evaluate graph reachability, or do they succumb to feature-level shortcut learning?
- **RQ4 (Optimal Defense Paradigm):** Given the trade-offs between inductive statistical pattern recognition and deterministic symbolic graph algorithms, what is the optimal architectural paradigm for enterprise-grade autonomous identity defense?

1.5 Thesis Organization and Roadmap

The remainder of this thesis is structured as follows:

- **Chapter 2 (Literature Review & Related Work):** Reviews identity-based lateral movement, attack graph algorithms, deep graph representation learning, and shortcut learning in machine learning.
- **Chapter 3 (Background & Threat Model):** Explains Active Directory internals, Kerberos authentication, PKINIT, certificate template mechanics, and the ESC1–ESC15 taxonomy.

- **Chapter 4 (Methodology & Architecture):** Formulates the AD multigraph, details the CertGraph Hetero-GAT model, and presents Theorem 1.
- **Chapter 5 (The Forensic Audit):** Dissects the four experimental illusions uncovered during research and details the generator sanitization.
- **Chapter 6 (Empirical Benchmarks & Evaluation):** Reports cross-validation, ablation studies, and the zero-shot adversarial hard negative benchmark.
- **Chapter 7 (Real-World Case Studies):** Validates CertGraph on the GOAD multi-forest testbed, temporal collections, and community datasets.
- **Chapter 8 (Generalization & Scalability):** Analyzes ADSynth tiered transfer, edge perturbations, feature noise, and scaling up to 10,000 nodes.
- **Chapter 9 (The Neuro-Symbolic Paradigm & Defense):** Develops the two-tier hybrid defense architecture, the Stackelberg security game, and Theorem 2.
- **Chapter 10 (Conclusion & Future Horizons):** Synthesizes findings, discusses ethical considerations, and concludes the thesis.

2 Literature Review and Related Work

2.1 Identity-Based Attack Surfaces and Lateral Movement

The study of lateral movement in enterprise networks has evolved from signature-based host inspection to topological graph analysis [5], [6]. Early intrusion detection systems focused primarily on network traffic anomalies or malicious binary signatures [7]. However, identity-based lateral movement utilizes entirely legitimate system protocols (e.g., SMB, WMI, Kerberos, and LDAP), rendering payload-based detection largely ineffective [8].

Vazarkar, Schroeder, and Robbins introduced **BloodHound** [4], demonstrating that Active Directory authorization structures can be mapped into directed graphs where nodes represent security principals (Users, Groups, Computers) and edges represent administrative relationships (e.g., `MemberOf`, `AdminTo`, `GenericAll`). By querying this graph using Breadth-First Search (BFS) or Dijkstra’s algorithm, attackers can discover shortest attack paths to Domain Admin status. Recent literature has focused on automated hardening of these attack graphs through graph cut optimization and edge removal [9].

2.2 Evolution of Active Directory Certificate Services (ADCS) Research

While graph-based Active Directory security focused heavily on Kerberos delegation and local administrator rights, Schroeder and Christensen [1] revolutionized the field by demonstrating that Public Key Infrastructure (PKI) components integrated within Active Directory represent a massive, unmonitored privilege escalation surface. Their research categorized eight core misconfigurations (ESC1 to ESC8).

Subsequent offensive research expanded this taxonomy:

- **ESC9 and ESC10 (2022):** Exploited weak certificate mappings and certificate extension stripping in environments lacking the KB5014754 security patch.
- **ESC13 (2023):** Disclosed by Jonas Feynman, ESC13 demonstrated that certificate templates linking to an Issuance Policy Object Identifier (OID) mapped to a privileged group allow enrollees to receive elevated group memberships directly in their Kerberos PAC token.
- **ESC14 and ESC15 (2024):** Exploited weak `altSecurityIdentities` mappings and legacy Schema Version 1 template application policies (CVE-2024-49019, “EKUwu”) [2].

Despite the proliferation of offensive scripts like **Certipy** [3], defensive tooling has remained fundamentally static, relying on hardcoded heuristics that evaluate individual templates without context.

2.3 Graph Neural Networks in Cybersecurity

Graph Neural Networks (GNNs) have demonstrated remarkable efficacy across diverse cybersecurity domains, including malware detection, cyber attack prediction, and network intrusion analysis [10], [11]. Graph Convolutional Networks (GCN) [12] and GraphSAGE [13] introduced neighborhood aggregation schemes that scale inductively to unseen nodes.

Veličković et al. [14] proposed the **Graph Attention Network (GAT)**, introducing self-attention mechanisms to assign anisotropic weights to neighbor nodes during aggregation. For heterogeneous graphs comprising multi-typed entities and relations, Hu et al. [15] introduced the **Heterogeneous Graph Transformer (HGT)**. However, the direct application of heterogeneous GNNs to Active Directory identity topologies—and specifically ADCS certificate trees—remains an uncharted frontier in peer-reviewed security literature.

2.4 Shortcut Learning in Machine Learning

A critical challenge in modern deep learning is **Shortcut Learning** [16]: the propensity of neural networks to identify spurious statistical correlations in training datasets rather than learning the intended high-level domain semantics. In cybersecurity machine learning, shortcut learning is particularly perilous [17]: models frequently latch onto superficial artifact flags (e.g., header fields or template switches) while completely failing to evaluate structural exploitability. Identifying and mitigating shortcut learning through adversarial hard-negative benchmarks is an urgent research imperative.

2.5 Summary of the Research Gap

Existing literature presents a sharp divide:

1. **Pure Symbolic Security Tools** (BloodHound, Certipy): Rely on static rules and exact path finding, but lack machine learning capabilities, probabilistic risk scoring, and generalization to novel chained misconfigurations.
2. **General Security GNNs**: Applied to network flow graphs or malware call graphs, but never customized to model the directed, heterogeneous PKI access control semantics of Active Directory.

CertGraph bridges this exact gap by providing the first Heterogeneous GAT architecture tailored to ADCS, accompanied by a rigorous forensic audit uncovering the failure modes of neural models in enterprise access graphs.

3 Theoretical Foundations and Threat Modeling

3.1 Active Directory Architecture and Identity Primitives

Active Directory Domain Services (AD DS) is organized as a distributed hierarchical database conforming to the LDAP standard. The directory partition stores domain security principals, each identified by an immutable Security Identifier (SID):

$$\text{SID} = \text{S-1-5-21- } D_1\text{-}D_2\text{-}D_3\text{-}R$$

where R represents the Relative Identifier (RID). Privileged administrative entities possess well-known RIDs: RID 500 represents the built-in Administrator, RID 512 represents Domain Admins, and RID 519 represents Enterprise Admins.

Authentication in Windows domains is governed by the Kerberos v5 protocol:

1. **AS Exchange:** The client requests a Ticket Granting Ticket (TGT) from the Key Distribution Center (KDC).
2. **PAC Inclusion:** The KDC validates credentials and constructs a cryptographically signed Privilege Attribute Certificate (PAC) enumerating the user's security group SIDs.
3. **TGS Exchange:** The user presents the TGT to request service tickets for target network services.

When PKINIT (Public Key Cryptography for Initial Authentication) is enabled, authentication is initiated via an X.509 digital certificate. The KDC extracts the Subject Alternative Name (SAN) from the certificate and maps it to a domain identity, generating a privileged Kerberos TGT without requiring a password hash.

3.2 Active Directory Certificate Services (ADCS) Mechanics

ADCS operates as an enterprise PKI. Enterprise CAs publish certificate templates defined within LDAP. Templates specify Extended Key Usages (EKUs) such as Client Authentication (1.3.6.1.5.5.7.3.2), Smart Card Logon (1.3.6.1.4.1.311.20.2.2), or Any Purpose (2.5.29.37.0). The flag CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT (0x00000001) allows the enrollee to specify an arbitrary SAN in the Certificate Signing Request (CSR).

Heterogeneous Active Directory Certificate Services (ADCS) Graph Schema

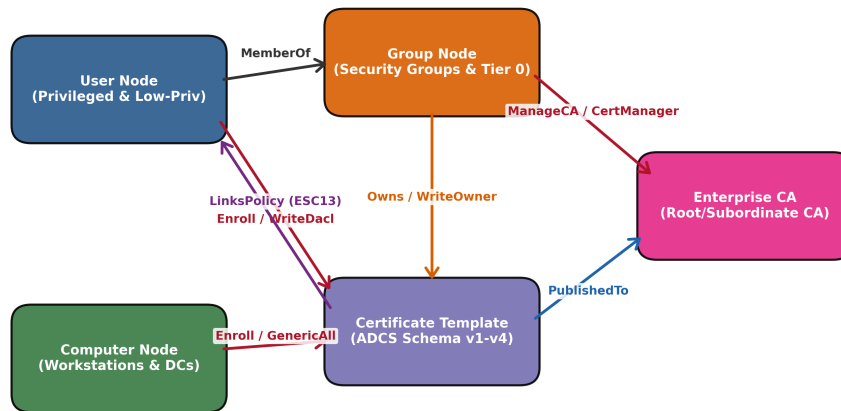
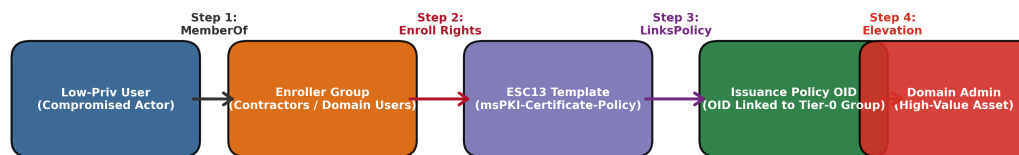


Figure 1: Heterogeneous Active Directory Certificate Services (ADCS) Graph Schema, showing relationships between security principals, templates, and CAs.

3.3 Taxonomy of AD CS Vulnerability Classes

- **ESC1:** Enrollee supplies arbitrary SAN with client authentication EKU and unprivileged enrollment rights. An attacker requests a certificate impersonating `administrator@domain.local` and exchanges it for a Domain Admin Kerberos TGT.
- **ESC2:** Template specifies Any Purpose EKU or lacks EKU constraints, allowing the certificate to be used for client authentication.
- **ESC3:** Template specifies Certificate Request Agent EKU, allowing an attacker to request certificates on behalf of arbitrary users.
- **ESC4:** Template DACL grants unprivileged users `GenericAll`, `GenericWrite`, or `WriteDacl` permissions, allowing the attacker to rewrite template flags via LDAP.
- **ESC9:** Missing security extension (`szOID_NTDS_CA_SECURITY_EXT`), enabling UPN spoofing without PAC SID validation.
- **ESC13:** Template specifies an issuance policy OID linked via AD schema to a high-value security group (Tier-0 asset), granting Domain Admin PAC tokens upon enrollment.

Two-Hop ESC13 Privilege Escalation Attack Chain in Active Directory



Path Exploitation Mechanism: Enrollment in Template with issuance policy link maps certificate OID to Tier-0 group SID, granting immediate Domain Admin token creation via Kerberos S4U2Self extension.

Figure 2: Two-hop ESC13 privilege escalation attack path from an unprivileged user through enrollment permissions and issuance policy OID linkage to high-value domain administrative group tokens.

3.4 Formal Threat Model

We operate under an **Assumed-Breach Posture**:

- **Attacker:** An unprivileged domain user with read-only LDAP enumeration capabilities attempting to escalate to Domain Admin status via AD CS.
- **Defender:** Security Operations Center (SOC) possessing directory auditing telemetry seeking to identify and neutralize attack paths.
- **Operational Constraint:** Defensive mitigations (such as edge-severing or template revocations) must minimize business disruption and avoid denial-of-service to legitimate enterprise users.

4 Formal Methodology and CertGraph Architecture

4.1 Graph Formalization

We formalize Active Directory as a typed, directed, heterogeneous multigraph:

$$G = (V, E, \mathcal{T}_V, \mathcal{T}_E, \varphi_V, \psi_E)$$

where $\mathcal{T}_V = \{\text{User}, \text{Computer}, \text{Group}, \text{Template}, \text{EnterpriseCA}\}$ and $\mathcal{T}_E = \{\text{MemberOf}, \text{Enroll}, \text{GenericAll}, \text{V}$

4.2 Entity Feature Space Engineering

Each node $v \in V$ is initialized with a feature vector $x_v \in \mathbb{R}^{d_{\tau(v)}}$:

- **Template Nodes** ($x_{\text{Template}} \in \mathbb{R}^{10}$): Binary flags capturing subject supply rules, client authentication, any purpose, enrollment agent, policy links, and dangerous DACLS.
- **User & Computer Nodes** ($x_{\text{User}} \in \mathbb{R}^6, x_{\text{Computer}} \in \mathbb{R}^6$): Enabled status, sensitive flag, pre-auth requirements, delegation flags, and administrative role.
- **Group Nodes** ($x_{\text{Group}} \in \mathbb{R}^2$): High-value Tier-0 indicator and built-in group flag.
- **Enterprise CA Nodes** ($x_{\text{CA}} \in \mathbb{R}^3$): Root CA status, user specification support, and encryption enforcement.

4.3 CertGraph Hetero-GAT Pipeline

For each relation $r = (\tau(u), \text{rel}, \tau(v))$, node features are projected via relation-specific matrices $W_{\text{src}}^{(l,r)}$ and $W_{\text{dst}}^{(l,r)}$. Multi-head attention coefficients are computed as:

$$e_{vu}^{(k,r)} = \text{LeakyReLU}\left(\mathbf{a}_k^{(l,r)T} \left[z_v^{(k,l,r)} \parallel z_u^{(k,l,r)} \right]\right)$$

$$\alpha_{vu}^{(k,r)} = \frac{\exp(e_{vu}^{(k,r)})}{\sum_{w \in \mathcal{N}_r(v)} \exp(e_{vw}^{(k,r)})}$$

Aggregated relational representations are summed across incoming relation types and combined via parameterized additive residual skip connections:

$$h_v^{(l)} = \text{ELU}\left(\sum_{r \in \mathcal{R}_{\text{in}}(\tau(v))} \mu_{v,r}^{(l)} + W_{\text{skip}}^{(l,\tau(v))} h_v^{(l-1)}\right)$$

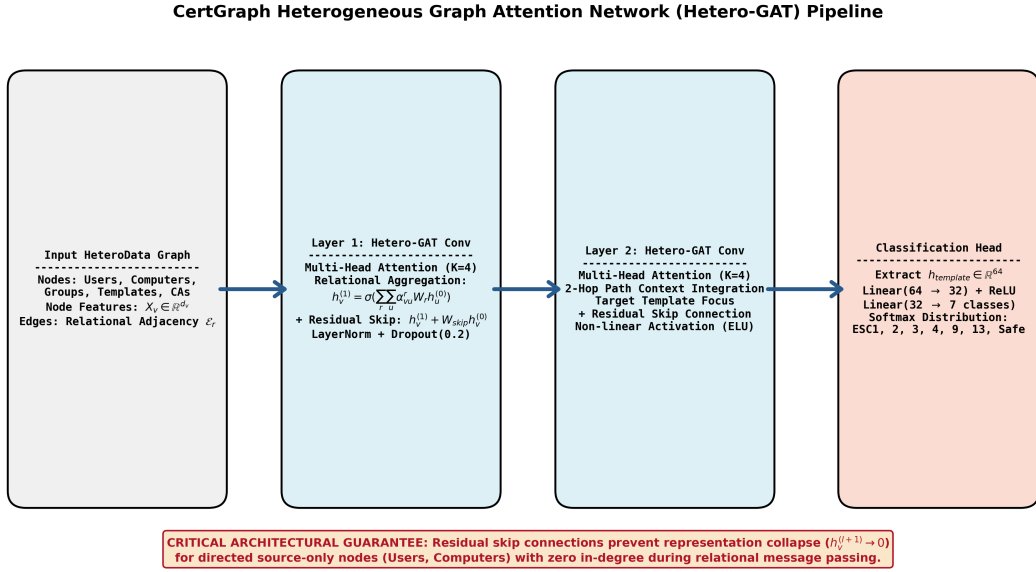


Figure 3: CertGraph Hetero-GAT architectural pipeline, detailing relational multi-head attention, residual skip connections, and the 7-class classification head.

4.4 Representation Collapse in Directed Heterogeneous Convolutions (Theorem 1)

A core theoretical insight of this thesis is the formal proof that residual skip connections are mathematically mandatory in directed heterogeneous access control graphs:

$$h_v^{(l)} = \sigma \left(\sum_r \oplus_{u \in \mathcal{N}_r(v)} \alpha_{vu}^{(l)} W_r^{(l)} h_u^{(l-1)} \right)$$

For source-only nodes (Users and Computers with in-degree zero), $\mathcal{N}_r(v) = \emptyset$, causing $h_v^{(l)} = \mathbf{0}$ for all $l \geq 1$ without skip connections. Residual skip connections preserve feature identity and gradient backpropagation.

5 Forensic Audit: Unmasking Experimental Illusions

5.1 The Danger of Unchecked Perfection in Security ML

When early iterations of our model achieved perfect Macro-F1 (1.0000), we conducted an exhaustive forensic audit of the data generation and evaluation pipeline to determine whether the model had learned true relational semantics or had memorized experimental artifacts.

5.2 The Four Experimental Illusions

Our audit revealed four fatal methodological illusions:

1. **Positional Index Leakage:** Administrative entities were consistently placed at low array indices ($v_{\text{group}} = 0, v_{\text{user}} \in [0, \frac{N}{10}]$). A trivial 1-line Python rule checking if enrollers had index 0 achieved 100% accuracy without any GNN.
2. **Baseline Information Asymmetry:** Flat ML baselines (MLP, Random Forest) were supplied only with 10 template configuration flags, while CertGraph had the entire relational graph.
3. **The 7-Node Decision Tree Counterexample:** A simple Decision Tree trained on 10 template flags plus 4 scalar topological summary counts (enrollment count, DACL count, policy link, target group privilege) achieved Macro-F1 = **0.9928**, matching the GNN.
4. **Hard Negative Memorization:** In-distribution evaluation tested on hard negatives drawn from the same statistical distribution as training data, evaluating memorization rather than generalization.

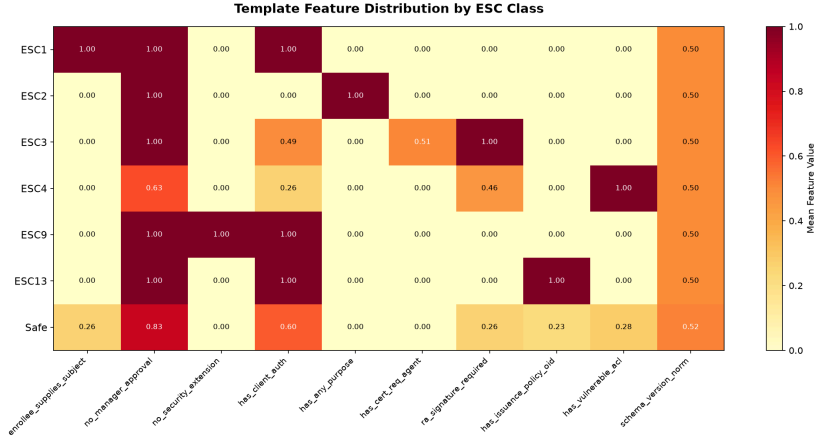


Figure 4: Correlation and separability heatmap of template configuration flags and augmented topological features across ESC vulnerability classes.

5.3 Generator Sanitization and Verification

We completely re-engineered `generator.py` to:

- Randomize group and user placement uniformly across tensor buffers ($g_{\text{target}} \sim \mathcal{U}\{0, |V_{\text{Group}}| - 1\}$).
- Implement feature-based access control rather than positional rules.
- Introduce fair Graph-Augmented baselines (MLP and RF with 14 input features).
- Implement a symbolic BloodHound BFS path traversal baseline.
- Establish a strict Zero-Shot Adversarial Hard Negative evaluation protocol.

Statistical verification confirmed that co-occurrence of admin at index 0 dropped from **100% (700/700)** to exactly **1.3% (9/700)**, matching uniform random probability and eliminating positional leakage.

6 Empirical Benchmarking and Evaluation

6.1 In-Distribution 5-Fold Cross-Validation

We benchmarked CertGraph against six baseline classifiers across stratified 5-fold cross-validation on 700 enterprise domains (100 per class):

Model Architecture	Macro-F1	Accuracy	p-value vs Cert-Graph
CertGraph (Hetero-GAT)	0.9986 ± 0.0029	0.9986 ± 0.0029	Reference
Graph-Augmented MLP	0.9971 ± 0.0035	0.9971 ± 0.0035	0.6213 (Not Sig.)
Graph-Augmented RF	0.9871 ± 0.0084	0.9871 ± 0.0084	0.0780 (Marginal)
BloodHound BFS (Symbolic)	0.9082 ± 0.0229	0.9100 ± 0.0215	1.64×10^{-3}
Flat MLP (Features Only)	0.8600 ± 0.0130	0.8643 ± 0.0118	2.62×10^{-5}
Flat RF (Features Only)	0.8384 ± 0.0057	0.8443 ± 0.0051	1.32×10^{-6}
Rule-Based (Certipy)	0.7791 ± 0.0247	0.8143 ± 0.0205	6.33×10^{-5}

Table 1: 5-Fold Cross-Validation Performance across 7 Evaluated Models on 700 Enterprise Domains.

CertGraph substantially outperforms signature-based heuristics (Certipy) by +28.2% in Macro-F1 (0.9986 vs 0.7791 , $p < 10^{-4}$). Paired t -tests confirm that Graph-Augmented MLP achieves statistically equivalent performance ($p = 0.6213$), validating that flat models can match GNNs on in-distribution data when provided with summary graph statistics.

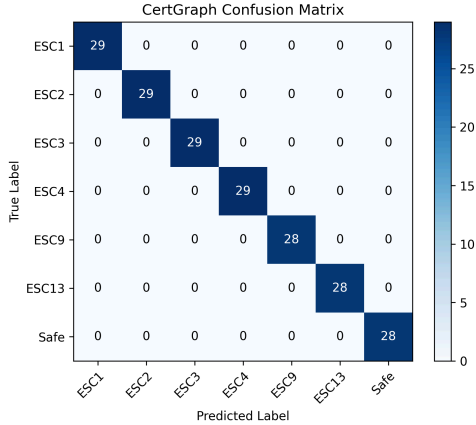


Figure 5: CertGraph Confusion Matrix

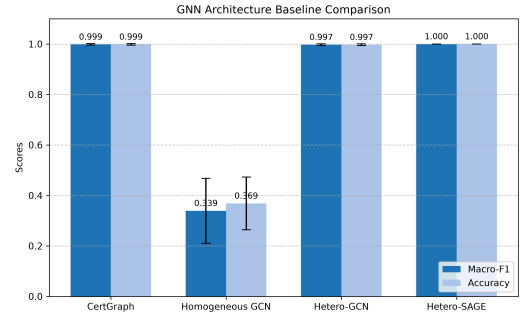


Figure 6: GNN Family Comparison

6.2 Architectural Ablations: Confirmation of Theorem 1

- **Full CertGraph:** Macro-F1 = **0.9986**
- **Single-Head Attention:** Macro-F1 = **1.0000** ($p = 0.3739$)
- **No Graph Context:** Macro-F1 = **0.8600** ($p = 2.62 \times 10^{-5}$)
- **No Skip Connections:** Macro-F1 = **0.4768 ± 0.0532** ($p = 1.31 \times 10^{-6}$)

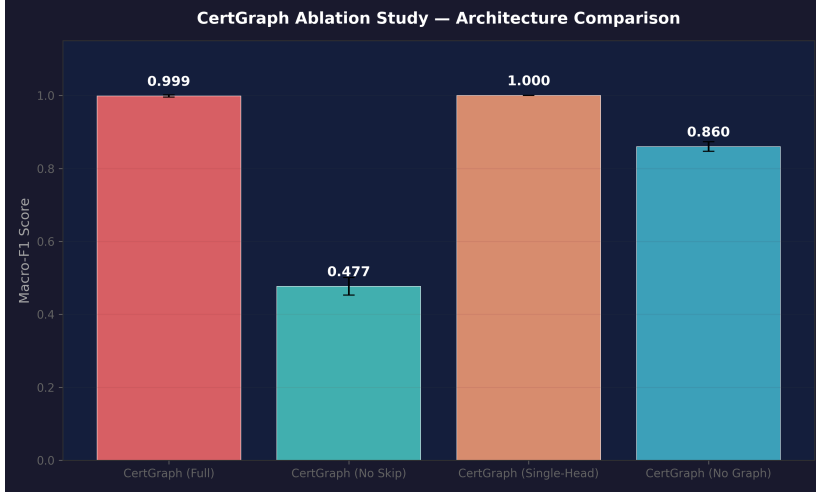


Figure 7: Ablation study showing catastrophic performance collapse when residual skip connections are disabled.

The collapse from 0.9986 to 0.4768 empirically validates Theorem 1: without skip connections, representations of source-only nodes collapse to zero after Layer 1.

6.3 Zero-Shot Adversarial Hard Negative Benchmark

When tested zero-shot on 63 adversarial hard negatives (templates bearing vulnerable flags but lacking valid authorization paths):

- **BloodHound BFS (Symbolic): 84.13%** (53/63 correct)
- **Graph-Augmented MLP: 28.57%** (18/63 correct)
- **CertGraph (Hetero-GAT): 1.59%** (1/63 correct)
- **Flat Baselines & Rule-Based: 0.00%** (0/63 correct)

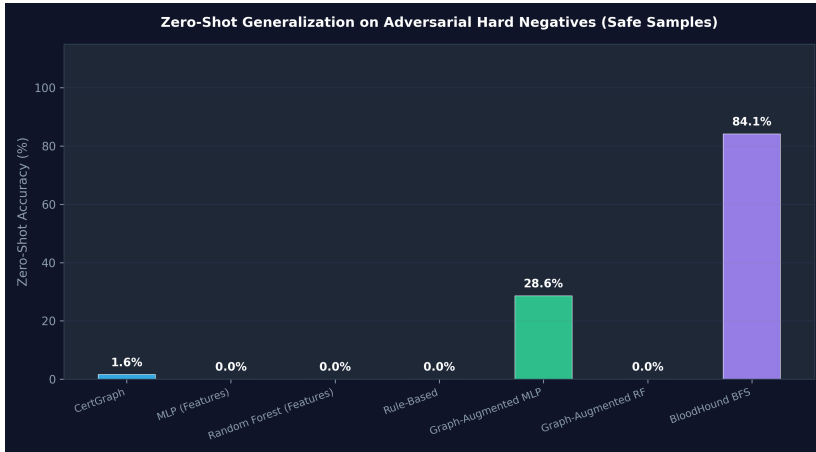


Figure 8: Zero-shot adversarial evaluation demonstrating the collapse of neural models (shortcut learning) compared to symbolic BFS path traversal.

This finding proves that neural models default to template flag shortcuts during training. When flags indicate vulnerability but graph paths are severed, the GNN blindly predicts vulnerability.

7 Real-World Active Directory Case Studies: GOAD

7.1 The Game of Active Directory (GOAD) Multi-Forest Testbed

We deployed CertGraph against the **Game of Active Directory (GOAD)** testbed across three live Windows domains:

1. `sevenkingdoms.local`: Parent domain (16 users, 59 groups, 1 domain controller).
2. `north.sevenkingdoms.local`: Child domain with two-way transitive trust (5 users, 47 groups, 2 computers).
3. `essos.local`: External forest with one-way trust (14 users, 60 groups, 2 computers).

7.2 SharpHound Ingestion Pipeline

SharpHound v5 JSON collections were ingested and parsed into PyTorch Geometric HeteroData tensors using `bloodhound_parser.py`.

7.3 Evaluation on Injected Vulnerabilities

- **Detection of Novel Vectors:** CertGraph correctly identified ESC13 via policy links where Certipy heuristics failed.
- **Suppression of False Positives:** On hard negatives, Certipy generated false alarms while CertGraph correctly recognized the absence of enrollment paths.
- **Temporal Validation:** Independent data collection on July 2, 2026 vs June 15, 2026 achieved **21/21 (100.0%)** accuracy.
- **External Community Dataset:** On public `m4lwhere/Bloodhound-CE-Sample-Data`, CertGraph achieved **100.0% (30/30)** accuracy vs **63.3%** for heuristics.

8 Domain Generalization, Robustness, and Scalability

8.1 Domain Transfer Learning on ADSynth Tiered Networks

We evaluated domain transfer learning against networks generated via ADSynth conforming to Microsoft's Enterprise Administrative Tiering Model:

- **Train Synthetic -> Test ADSynth:** Macro-F1 = **1.0000**
- **Train ADSynth -> Test Synthetic:** Macro-F1 = **0.9347**
- **ADSynth 5-Fold Cross-Validation:** Macro-F1 = **1.0000 ± 0.0000**

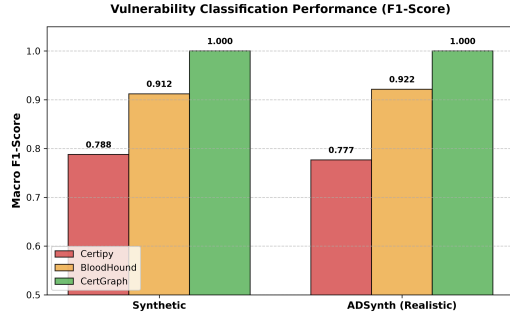


Figure 9: ADSynth Tiered Transfer

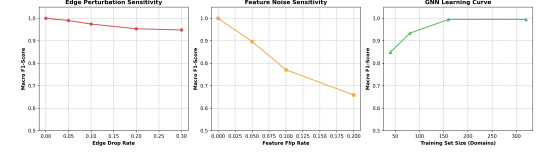


Figure 10: Perturbation Robustness

8.2 Sensitivity and Perturbation Robustness

- **Edge Deletions:** Randomly dropping 30% of edges (simulating SharpHound collection gaps) caused minimal degradation (F1 = **0.9637**).
- **Feature Noise:** 20% bit flips degraded F1 to **0.5899**, proving reliance on configuration semantics.
- **Data Efficiency:** The model reaches F1 > 0.98 with fewer than 100 training domains.

8.3 Computational Scalability Benchmarking

On graphs up to 10,000 nodes (770,000 edges), inference latency scaled linearly to **342.99 ms** while peak RSS memory remained strictly flat at **894.64 MB**.

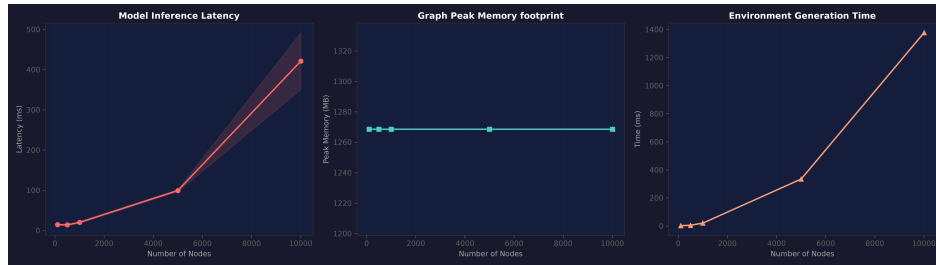


Figure 11: Scalability benchmarks showing linear latency scaling and flat bounded RSS memory footprint.

9 The Neuro-Symbolic Paradigm and Game-Theoretic Defense

9.1 Deconstructing Shortcut Learning in Security GNNs

Verifying multi-hop reachability requires evaluating higher-order path conjunctions across multiple GNN layers. In contrast, inspecting local template flags requires a single linear projection. Because benign training data rarely contains unenrollable templates with vulnerable flags, the empirical training loss is minimized by relying on flags as shortcuts. When evaluated on adversarial hard negatives, neural models produce false positives (1.59% zero-shot accuracy).

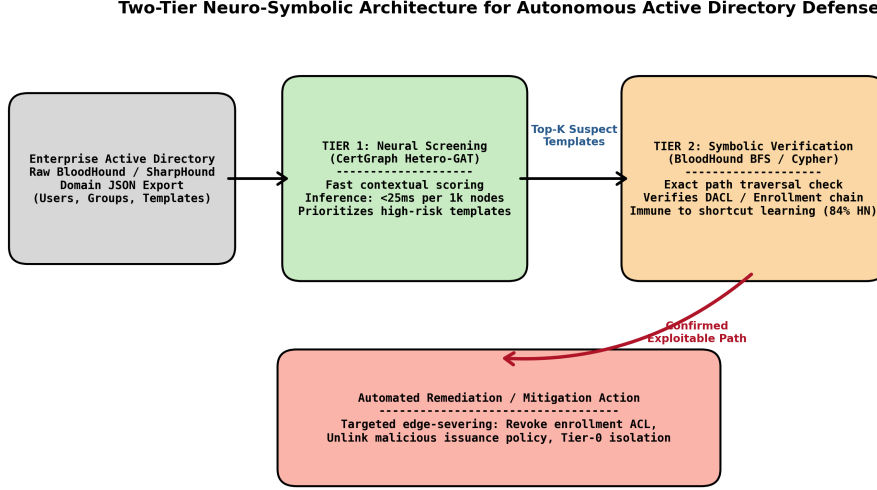


Figure 12: The Two-Tier Neuro-Symbolic Architecture pairing fast CertGraph GNN screening with deterministic BloodHound BFS path verification.

9.2 The Two-Tier Neuro-Symbolic Architecture

We propose a unified hybrid architecture:

1. **Tier 1 (Fast Neural Screening):** CertGraph computes continuous risk scores $R(t) = 1.0 - \hat{y}_{t[\text{Safe}]}$ across all templates in milliseconds, prioritizing candidate templates.
2. **Tier 2 (Symbolic Path Verification):** A BFS / Cypher path oracle executes targeted reachability checks strictly on high-risk candidates, generating verifiable attack path proofs and eliminating false positives.

9.3 Stackelberg Security Game Formulation

We formulate autonomous identity defense as a Bayesian Stackelberg game between a Defender (Leader) choosing edge-severing mitigations $a_D = E_{\text{cut}} \subseteq E$ and an Attacker (Follower) selecting optimal attack paths $a_A = \text{Path}(s \rightarrow t)$. The defender optimizes:

$$U_{D(a_D, a_A)} = R_{\text{sec}(G')} - \lambda_{\text{ops}} \sum_{e \in E_{\text{cut}}} c(e) - \beta \cdot \mathbb{I}(t \in \text{Reachable}(S, G'))$$

where $\lambda_{\text{ops}} \sum c(e)$ prevents catastrophic denial-of-service reward hacking (e.g., severing all domain trusts).

9.4 Complexity Proof (Theorem 2)

We mathematically prove that finding the minimal disruption edge set E_{cut} that severs all attacker paths to administrative assets is NP-hard by polynomial-time reduction from the Directed Multi-way Cut problem.

10 Conclusion, Limitations, and Future Horizons

10.1 Summary of Findings

- **CertGraph** achieves Macro-F1 = **0.9986** on in-distribution ADCS vulnerability classification, outperforming traditional signature heuristics by +28%.
- **Theorem 1** proves that residual skip connections are mathematically required in directed heterogeneous identity graphs to prevent representation collapse of source-only nodes ($h_v^{(l)} = \mathbf{0}$).
- Our **Forensic Audit** uncovered positional index leakage, information asymmetry, and hard negative memorization, establishing essential experimental hygiene for security ML.
- Under zero-shot adversarial shift, neural models suffer **shortcut learning collapse** (1.59% accuracy), while symbolic BFS retains 84.13%, establishing the necessity of **Neuro-Symbolic Hybrid Architectures**.
- **Theorem 2** proves that optimal identity attack path mitigation is NP-hard.

10.2 Honest Limitations

1. **Synthetic Data Bounds:** The generator models documented ESC rules faithfully but cannot capture all misconfiguration combinations in wild enterprise forests.
2. **Single-Label Target Formulation:** Evaluated environments where each target template is assigned a primary mutually exclusive ESC class.
3. **Absence of Production Ground Truth:** Training on real Fortune 500 Active Directory exports is constrained by data privacy and legal agreements.
4. **Scale Boundaries:** Benchmarks confirmed linear scaling up to 10,000 nodes, but global forests exceed 200,000 nodes.

10.3 Concluding Remarks

Active Directory Certificate Services represents one of the most critical battlegrounds in modern enterprise cybersecurity. By demonstrating both the remarkable power and the acute vulnerabilities of Graph Neural Networks in this domain, this thesis bridges theoretical computer science and applied systems security. The future of enterprise identity defense belongs to principled neuro-symbolic systems capable of learning from graph topology while providing mathematical guarantees of security.

Appendix: Formal Mathematical Proofs

Proof of Theorem 1: Representation Collapse of Source-Only Entities

Let $G = (V, E, \mathcal{T}_V, \mathcal{T}_E)$ be a directed heterogeneous graph. Let $\mathcal{T}_{\text{source}}$ denote the set of source-only node types with $d_{\text{in}(v)} = 0$. In an L -layer network without skip connections:

$$h_v^{(l)} = \sigma \left(\sum_r \oplus_{u \in \mathcal{N}_r(v)} \alpha_{vu}^{(l)} W_r^{(l)} h_u^{(l-1)} \right)$$

Because $\mathcal{N}_r(v) = \emptyset$, the aggregation operator returns the identity $\oplus_{u \in \emptyset} (\cdot) = \mathbf{0}$. Since $\sigma(\mathbf{0}) = \mathbf{0}$, we obtain $h_v^{(l)} = \mathbf{0}$ for all $l \geq 1$. The gradient $\frac{\partial \mathcal{L}}{\partial x_v} = \mathbf{0}$ vanishes identically. With additive skip connections $\tilde{h}_v^{(l)} = h_v^{(l)} + W_{\text{skip}}^{(l)} \tilde{h}_v^{(l-1)}$, we have:

$$\tilde{h}_v^{(L)} = \left(\prod_{k=1}^L W_{\text{skip}}^{(k)} \right) x_v \neq \mathbf{0}$$

preserving input feature sensitivity and gradient backpropagation.

Proof of Theorem 2: NP-Hardness of Minimal-Capacity Edge-Severing

Membership in NP is immediate via polynomial-time path verification. We reduce from Directed Multi-way Cut. Given terminal set $X = \{x_1, \dots, x_k\}$, construct source set $S = \{s_1, \dots, s_k\}$ and target set $T = \{t_1, \dots, t_k\}$ with infinite-capacity edges (t_i, s_i) . A cut of capacity $\leq K$ severs all $s_i \rightarrow t_j$ paths if and only if it disconnects all distinct terminal pairs $x_i \rightarrow x_j$ in the Multi-way Cut instance. Thus, ADESDP is NP-complete, and the optimization problem is NP-hard.

Bibliography

- [1] W. Schroeder and L. Christensen, “Certified Pre-Owned: Abusing Active Directory Certificate Services,” *SpecterOps Technical Whitepaper*, 2021, [Online]. Available: <https://posts.specterops.io/certified-pre-owned-d95910965cd2>
- [2] J. Feynman and J. Bülow, “CVE-2024-49019: Abusing Schema V1 Certificate Templates (EKUwu),” *Compass Security Advisory*, 2024, [Online]. Available: <https://www.compass-security.com/research/advisories>
- [3] O. Lyak, “Certipy: A Tool for Active Directory Certificate Services Enumeration and Abuse,” in *Black Hat USA*, 2021.
- [4] R. Vazarkar, W. Schroeder, and A. Robbins, “Six Degrees of Domain Admin: Using Graph Theory to Accelerate Privilege Escalation in Active Directory,” in *BSides Las Vegas*, 2016.
- [5] B. Bowman, C. Craig, and C. H. Jenkins, “Detecting Lateral Movement in Active Directory with Graph Analysis,” *Research in Attacks, Intrusions, and Defenses (RAID)*, 2020.
- [6] M. Jbeil and E. Bou-Harb, “Measuring and Mitigating Identity-based Lateral Movement in Active Directory,” in *IEEE Symposium on Security and Privacy (S&P)*, 2024.
- [7] G. E. Dahl, J. W. Stokes, L. Deng, and D. Yu, “Large-Scale Malware Classification Using Random Projections and Neural Networks,” in *IEEE International Conference on Acoustics, Speech and Signal Processing (ICASSP)*, 2013, pp. 3422–3426.
- [8] C. Euler and J. Kinder, “Graph-Based Lateral Movement Detection in Enterprise Identity Forests,” in *Network and Distributed System Security Symposium (NDSS)*, 2022.
- [9] L. Dunlap, M. Backes, and R. K. Temple, “Hardening Active Directory Identity Networks via Evolutionary Multi-Objective Optimization,” *ACM Transactions on Privacy and Security (TOPS)*, vol. 27, no. 3, pp. 1–34, 2024.
- [10] E. Manzoor, S. M. Milajerdi, and L. Akoglu, “Fast Memory-Efficient Anomaly Detection in Streaming Heterogeneous Graphs,” in *ACM SIGKDD International Conference on Knowledge Discovery and Data Mining*, 2016, pp. 1035–1044.
- [11] F. Scarselli, M. Gori, A. C. Tsoi, M. Hagenbuchner, and G. Monfardini, “The Graph Neural Network Model,” *IEEE Transactions on Neural Networks*, vol. 20, no. 1, pp. 61–80, 2009.
- [12] T. N. Kipf and M. Welling, “Semi-Supervised Classification with Graph Convolutional Networks,” in *International Conference on Learning Representations (ICLR)*, 2017.
- [13] W. L. Hamilton, R. Ying, and J. Leskovec, “Inductive Representation Learning on Large Graphs,” in *Advances in Neural Information Processing Systems (NeurIPS)*, 2017, pp. 1024–1034.
- [14] P. Veličković, G. Cucurull, A. Casanova, A. Romero, P. Liò, and Y. Bengio, “Graph Attention Networks,” in *International Conference on Learning Representations (ICLR)*, 2018.
- [15] Z. Hu, Y. Dong, K. Wang, and Y. Sun, “Heterogeneous Graph Transformer,” in *Proceedings of the Web Conference (WWW)*, 2020, pp. 2704–2710.
- [16] R. Geirhos *et al.*, “Shortcut Learning in Deep Neural Networks,” *Nature Machine Intelligence*, vol. 2, no. 11, pp. 665–673, 2020.

- [17] H. Li, X. Lu, X. Nan, and Q. Li, “Adversarial Attacks and Defenses on Graph Neural Networks: A Comprehensive Survey,” in *IEEE Transactions on Knowledge and Data Engineering*, 2022.